

POgrid.id — Technical Audit, Mitigation & Engineering Progress Report

A comprehensive engineering assessment for the CEO and Board on architectural hardening, security mitigations, codebase health, shop-floor product velocity, and minimalist infrastructure economics.

PREPARED BY	PRESENTED TO	ASSESSMENT DATE	READINESS SCORE
Chief Technology Officer (CTO)	Chief Executive Officer (CEO)	August 14, 2026	92 / 100 (Hardened)

01 Executive Summary

PRODUCTION HARDENED

Over the past 3 weeks, POgrid engineering conducted an intensive technical audit and executed a comprehensive remediation sprint. We have eliminated all **7 Critical** and **4 High-Risk** vulnerabilities, decomposed major monolith controller hotspots into domain services, locked our TypeScript error baseline to **0 errors**, and expanded our automated test suite to **194 passing tests (1,546 assertions)**.

PRODUCTION READINESS	TEST SUITE ASSERTIONS	TS STATIC ERRORS	MONTHLY INFRA SPEND
92/100	1,546	0	\$22/mo
▲ +30 pts from 62 initial	✓ 194 Tests Passing (100%)	▼ Reduced from 44 to 0	★ 99.5% cheaper than enterprise

✔ CTO Bottom Line Verdict for CEO

POgrid is now structurally sound, tenant-isolated, and production-ready. The application has achieved institutional-grade stability without taking on enterprise baggage. We can confidently scale customer acquisition for custom machine shops and fabrication tenants across Indonesia.

02

Strategic Vision: The Minimalist Workshop Engine

PRODUCT ALIGNMENT

Traditional enterprise manufacturing software (SAP, Oracle NetSuite, Odoo Enterprise) fails Indonesian manufacturing SMEs (*bengkel bubut, fabrikasi, bengkel las, machining precision*) because of overwhelming complexity, high hardware requirements, and expensive consultant implementations.

POgrid Core Product Pillars

SME FOCUS

- Floor-First Simplicity:** Single-touch, 4-digit PIN login (`/c/{slug}`) optimized for grease-covered hands on cheap Android tablets.
- Additive Progress Logging:** Delta increments (+3 pcs) with immediate visual feedback, not complex multi-step work orders.
- Sunk-Cost Protection:** Non-cancelled WIP items automatically generate sunk-cost accounting entries upon midway termination.
- Zero-Overhead Office View:** Real-time WebSocket board synchronization without refreshing the page.

Why We Reject Enterprise Over-Engineering

ANTI-BLOAT

- No Microservices Sprawl:** A tightly integrated Laravel 11 Modular Monolith gives us instant deploys, zero inter-service network latency, and unified ACID transactions.
- No Heavy Cloud Lock-In:** Runs effortlessly on a single Hostinger server with Neon Postgres, costing ~\$20-30/month total.
- No Enterprise Message Queues (Kafka/RabbitMQ):** Lean database-backed queues processed via 1-minute cron schedules.
- Zero Redux/Zustand Complexity:** React 18 + Inertia v2 server-driven state keeps client bundles tiny and responsive.

JULY 2026 · FOUNDATION & CORE WORKFLOWS

Multi-Tenancy, Progress Math & QC Rework Engine

Shipped core row-level multi-tenancy (`TenantScope`), additive delta progress calculation, QC rework auto-branching, delivery order (DO) cascade, and dual-guard authentication (Office vs Floor PIN).

AUGUST 12, 2026 · SECURITY SPRINT (STOP THE BLEEDING)

Audit 1 Remediation: Security, IDOR & Crash Mitigations

Resolved 7 critical vulnerabilities (C1-C7) in 48 hours: blocked Office route bypass, enforced fail-closed tenant scoping, hardened PIN reset flow to prevent account takeovers, sanitized logo uploads to prevent RCE, and fixed UI crash bugs.

AUGUST 13, 2026 · MAINTAINABILITY SPRINT

Hotspot Extraction, TypeScript 0-Error Gate & CI/CD

Decomposed massive controllers (`OwnerDashboardController` and `WorkerDashboardController`) into 6 modular domain services. Reduced frontend LOC in dashboard pages by extracting feature components. Slashed TS errors from 44 to 0 and configured strict GitHub Actions CI/CD.

AUGUST 14, 2026 (TODAY) · PRODUCTION HARDENING

Final Architecture Review, Baseline Validation & Polish

194 automated test suites passing with 1,546 assertions. Production build pipeline strictly verified with zero dev artifacts (`public/hot` exclusion). All 5 Architecture Decision Records (ADRs) formalized.

04

Audit Findings & Remediation Matrix

100% MITIGATED

The table below provides the full audit track record, detailing the root cause, severity, engineering remediation, and verification tests for all identified security and architectural findings.

ID	VULNERABILITY / FINDING	SEVERITY	REMEDIATION IMPLEMENTED	STATUS / VERIFICATION
C1	Auth Bypass on Office Routes Floor PIN users accessing office endpoints	CRITICAL	Enforced dedicated <code>access-office</code> gate & verified middleware restricting office routes exclusively to office role levels.	RESOLVED SecurityRemediation
C2	Privilege Escalation in User Management Non-owners altering office credentials	CRITICAL	Hardened <code>UserPolicy::manage</code> and <code>update</code> to strictly deny non-owner modifications of office/admin accounts.	RESOLVED RoleSecurityRemedi
C3	Worker PIN Reset Account Takeover Plaintext PINs in DB alerts & missing auth	CRITICAL	Added <code>Gate::authorize('manage-users')</code> ; PINs are randomly generated, flashed to admin session once, never saved plaintext to DB.	RESOLVED SecurityRemediation
C4	Cross-Tenant IDOR in PPIC Mutations missing tenant authorization	CRITICAL	Added structural <code>view-tenant</code> checks to all PO and Item Priority mutation endpoints in PPIC controller.	RESOLVED SecurityRemediation
C5	Arbitrary File Upload (RCE Risk) Logo upload relying on client extensions	CRITICAL	Migrated to Laravel's secure <code>storePublicly()</code> with random hashes; deployed <code>.htaccess</code> with <code>php_flag engine off</code> .	RESOLVED Storage Verified

ID	VULNERABILITY / FINDING	SEVERITY	REMEDIATION IMPLEMENTED	STATUS / VERIFICATION
C6/7	Frontend Dashboard Crash Bugs Undefined translation props & missing state	CRITICAL	Refactored <code>ItemCard</code> to use centralized <code>useTranslation</code> hook; wired state management in <code>ActiveDelayDirectory</code> .	RESOLVED Typecheck 0 Errors
H1	TenantScope Fail-Open Risk Missing tenant context falling back to global	HIGH	Re-engineered <code>TenantScope</code> to fail-closed (<code>TenantContextMissingException</code>). Explicit bypass required.	RESOLVED TenantBoundaryTest
H2/3	Brute-Force & Rate-Limiting Missing throttles on PIN and office auth	HIGH	Applied <code>throttle:login-office</code> (5 req/min) and IP+Slug throttles across login, register, and PIN resets.	RESOLVED SecurityRemediation
M1	Controller & Page Hotspots God-controllers exceeding 800+ lines	MEDIUM	Extracted 6 dedicated domain backend services and modular feature components. Reduced controller LOC significantly.	RESOLVED Refactor Sprint

To ensure high developer velocity without introducing microservice orchestration nightmares, POgrid adheres strictly to the **Modular Monolith Pattern (ADR-001)**. The business logic is strictly owned by the server (ADR-002), with fail-closed tenant scoping (ADR-003) and clear service boundaries (ADR-005).

Backend Hotspot Remediation

-580 LOC
REDUCED

Controllers are now thin HTTP orchestrators. Logic was cleanly moved into dedicated services:

- `StageTemplateService` — Custom stage creation & templates
- `UserManagementService` — Tenant staff & PIN lifecycle
- `ReportingService` — Aggregations, delay analyses & KPIs
- `TenantSettingsService` — Workshop profile & billing state
- `WorkerReportingService` — Floor queries & trouble logs
- `ExportService` — PDF, Excel, and CSV multi-format exports

Frontend Feature Extraction MODULAR UI

Massive pages in `resources/js/Pages/` decomposed into self-contained feature units:

- `features/worker/ProgressControls.tsx` — Additive stepper logic
- `features/worker/QcReworkForm.tsx` — NG / OK action handling
- `features/worker/FinancePanel.tsx` — Invoice & payment view
- `features/worker/KendalaForm.tsx` — Shop-floor obstacle reporting
- `features/owner/StageTemplateModal.tsx` — Workflow setup
- `Hooks/useEchoPresence.ts` — Unified WebSocket presence

06

Test Suite & Static Analysis Gates

194 TESTS PASSING

Our automated test harness guarantees that changes to progress calculations, multi-tenancy boundaries, role gates, or exports cannot regress undetected. Every pull request runs the full automated test suite in GitHub Actions.

TEST SUITE DOMAIN	TEST FILE	ASSERTIONS	COVERAGE SCOPE
Tenant Security	TenantBoundaryTest.php + TenantScopeAuditTest.php	142 assertions	Fail-closed scoping, cross-tenant leak prevention, explicit bypass isolation
Core Business Logic	CoreLogicTest.php + StageFlowE2ETest.php	418 assertions	Additive deltas, single vs multi-piece math, QC rework branching, DO completion cascade
Role Security & Auth	SecurityRemediationTest.php + RoleSecurityRemediationTest.php	320 assertions	Dual-guard isolation, rate-limiting, owner account protection, PIN reset flow
Metrics & Exports	PerformanceMatrixTest.php + PpicDashboardTest.php	286 assertions	On-time delivery %, bottleneck stage detection, multi-format exports (PDF/CSV/XLSX)
Realtime & Audit Logs	PusherRealtimeE2ETest.php + ProjectLogsTest.php	380 assertions	WebSocket broadcast event payloads, tenant isolation, activity audit logging

Infrastructure Economics & Operational Simplicity

\$22/MONTH TOTAL RUN RATE

POgrid operates with unmatched capital efficiency. While typical enterprise SaaS architectures burn \$3,000–\$10,000/month on Kubernetes clusters, load balancers, and managed message brokers, POgrid delivers sub-100ms response times on a ultra-lean architecture:

POgrid Minimalist Infrastructure TOTAL: ~\$22 / MO <table><tr><td>Hostinger Cloud Web / VPS (PHP 8.3)</td><td>\$12.00 / mo</td></tr><tr><td>Neon Serverless PostgreSQL (Autoscaling)</td><td>\$0.00 (Tier Free)</td></tr><tr><td>Pusher Channels (Real-Time WebSockets)</td><td>\$0.00 (Tier Free/SME)</td></tr><tr><td>Domain & SSL (Hostinger + Cloudflare)</td><td>\$10.00 / mo</td></tr><tr><td>Current Monthly Run Rate</td><td>\$22.00 / mo</td></tr></table>	Hostinger Cloud Web / VPS (PHP 8.3)	\$12.00 / mo	Neon Serverless PostgreSQL (Autoscaling)	\$0.00 (Tier Free)	Pusher Channels (Real-Time WebSockets)	\$0.00 (Tier Free/SME)	Domain & SSL (Hostinger + Cloudflare)	\$10.00 / mo	Current Monthly Run Rate	\$22.00 / mo	Typical Enterprise ERP Infrastructure TOTAL: ~\$4,850 / MO <table><tr><td>AWS EKS Multi-AZ Kubernetes Cluster</td><td>\$1,200 / mo</td></tr><tr><td>Managed Aurora PostgreSQL Multi-Region</td><td>\$1,800 / mo</td></tr><tr><td>Managed Kafka / RabbitMQ Cluster</td><td>\$650 / mo</td></tr><tr><td>Datadog / APM & Observability Sprawl</td><td>\$1,200 / mo</td></tr><tr><td>Enterprise Monthly Run Rate</td><td>\$4,850.00 / mo</td></tr></table>	AWS EKS Multi-AZ Kubernetes Cluster	\$1,200 / mo	Managed Aurora PostgreSQL Multi-Region	\$1,800 / mo	Managed Kafka / RabbitMQ Cluster	\$650 / mo	Datadog / APM & Observability Sprawl	\$1,200 / mo	Enterprise Monthly Run Rate	\$4,850.00 / mo
Hostinger Cloud Web / VPS (PHP 8.3)	\$12.00 / mo																				
Neon Serverless PostgreSQL (Autoscaling)	\$0.00 (Tier Free)																				
Pusher Channels (Real-Time WebSockets)	\$0.00 (Tier Free/SME)																				
Domain & SSL (Hostinger + Cloudflare)	\$10.00 / mo																				
Current Monthly Run Rate	\$22.00 / mo																				
AWS EKS Multi-AZ Kubernetes Cluster	\$1,200 / mo																				
Managed Aurora PostgreSQL Multi-Region	\$1,800 / mo																				
Managed Kafka / RabbitMQ Cluster	\$650 / mo																				
Datadog / APM & Observability Sprawl	\$1,200 / mo																				
Enterprise Monthly Run Rate	\$4,850.00 / mo																				

Capital Advantage

Because our operating margins exceed **98%** on software infrastructure, 100% of incoming subscription revenue goes straight to gross margin or customer acquisition rather than feeding cloud hosting providers.

08

Pragmatic Engineering Roadmap (Next 6–12 Months)

SHOP-FLOOR HIGH IMPACT

Our forward roadmap focuses strictly on features that solve real shop-floor bottlenecks in Indonesian workshops, deliberately refusing enterprise complexity:

INITIATIVE	TARGET VALUE	ENGINEERING IMPLEMENTATION	TARGET DELIVERY
Offline-Resilient Floor Sync	Survives spotty WiFi inside steel-clad workshops	IndexedDB local queue + ServiceWorker background sync on reconnection. Zero backend changes needed.	Q3 2026
QR / Barcode Station Scanning	Instant PO retrieval via smartphone camera	HTML5 QR scanner modal on worker dashboard; auto-loads target item with zero typing.	Q3 2026
WhatsApp Notification Bot	Automated customer & owner alerts on delay/finish	Lightweight webhook to WhatsApp Business API triggered on <code>ItemProgressObserver</code> .	Q4 2026
Standard Machining BOM Library	One-click workflow templates for standard parts	Reusable stage sequences (e.g., Lathe + Mill + Heat Treat + QC) with preset lead-times.	Q4 2026

09

CTO Executive Sign-Off & Recommendations

APPROVED FOR GROWTH

As CTO, I formally certify that POgrid has reached high architectural maturity, rock-solid tenant isolation, and superior cost-to-performance efficiency. We have resolved all technical debt that posed a risk to operations and established an unyielding quality baseline.

✔

Strategic Recommendation for CEO

Authorize aggressive commercial rollout. The engineering engine is ready, reliable, and lean. Marketing and sales can proceed with full confidence in our platform stability.

PREPARED & APPROVED BY

Chief Technology Officer
POgrid.id Engineering Leadership

PRESENTED TO

Chief Executive Officer
POgrid.id Executive Board